

■■ DevSecOps Executive Security & Audit Report

Generated: 2026-07-30T20:14:40.537538 | Scanners: Gitleaks, Hadolint, Trivy, zap

Total Findings	Total Risk Score	Overall Risk Level	Compliance Score
22	81 Pts	CRITICAL	77.8%

■ Framework Compliance Posture Breakdown

Framework	Compliance %	Controls Passed	Controls Failed
OWASP TOP 10 2021	70.0%	7 / 10	3
CIS BENCHMARKS	73.3%	11 / 15	4
NIST SP 800 53	90.0%	18 / 20	2

■ Detailed Findings Inventory

Severity	Tool	Rule ID	File / Location	Description
CRITICAL	Gitleaks	aws-access-token	testing/gitleaks/test_secret s.	Identified a pattern that may indicate AWS credentials, risking unauth
MEDIUM	Trivy	CVE-2026-48758	Node.js	sigstore-core: @sigstore/core: Signature bypass due to incorrect encod
HIGH	Trivy	GHSA-j4mr-9xw3-c9 jx	Node.js	Out-of-bounds Read in base64-url
HIGH	Trivy	NSWG-ECO-434	Node.js	Out-of-bounds Read
HIGH	Trivy	CVE-2026-13149	Node.js	brace-expansion: Brace-expansion: Denial of Service due to exponential
HIGH	Trivy	CVE-2026-14257	Node.js	brace-expansion through 5.0.7 is vulnerable to denial of service via m
MEDIUM	Trivy	CVE-2026-33750	Node.js	brace-expansion: brace-expansion: Denial of Service via zero step valu
MEDIUM	Trivy	CVE-2026-42338	Node.js	ip-address: ip-address: Cross-site scripting via improper HTML escapin
MEDIUM	Trivy	GHSA-664h-wqgg-6 4gw	Node.js	Mongoose: Prototype pollution in mongoose update casting via __proto__
HIGH	Trivy	GHSA-p6gq-j5cr-w3 8f	Node.js	Nodemailer: Message-level raw option bypasses disableFileAccess/disabl
HIGH	Trivy	CVE-2026-33671	Node.js	picomatch: Picomatch: Regular Expression Denial of Service via crafted
MEDIUM	Trivy	CVE-2026-33672	Node.js	picomatch: Picomatch: Data integrity compromised via method injection
HIGH	Trivy	CVE-2026-48815	Node.js	sigstore: Sigstore: Unauthorized certificates accepted due to ignored
CRITICAL	Trivy	CVE-2026-59873	Node.js	tar: node-tar: Denial of Service via crafted gzip bomb
HIGH	Trivy	CVE-2026-59874	Node.js	tar: Node-tar: Denial of Service via malformed tar archive header
MEDIUM	Trivy	CVE-2026-53655	Node.js	node-tar: node-tar: File smuggling due to inconsistent tar archive par

MEDIUM	Trivy	CVE-2026-59871	Node.js	node-tar: node-tar: Denial of Service due to incorrect PAX path handli
MEDIUM	Trivy	CVE-2026-59875	Node.js	node-tar: node-tar: Denial of Service via crafted archive with NUL byt
MEDIUM	Trivy	GHSA-r292-9mhp-454m	Node.js	node-tar: Uncontrolled recursion in mapHas/filesFilter allows uncatcha
LOW	OWASP ZAP	ZAP-10021	X-Content-Type-Options Header	X-Content-Type-Options Header Missing - The Anti-MIME-Sniffing header
MEDIUM	OWASP ZAP	ZAP-10038	Content Security Policy (CSP)	Content Security Policy (CSP) Header Not Set - Content Security Policy
INFO	Hadolint	DL3059	/workspace/app/client/Doc kerfi	Multiple consecutive `RUN` instructions. Consider consolidation.